

Network Security — Overview

OSI, ARP, DNS, TLS, IPSec and related
protocols

OSI Model (7 Layers)

- 7 Application — user services (HTTP, SMTP, DNS)
- 6 Presentation — formatting, encryption, compression
- 5 Session — session management, dialogs
- 4 Transport — end-to-end transport (TCP/UDP)
- 3 Network — routing, IP addressing (IP, ICMP)
- 2 Data Link — MAC, framing, switches (Ethernet, ARP)

CSMA/CD (Ethernet Access Control)

- Carrier Sense Multiple Access with Collision Detection
- Listen before transmit; detect collisions and abort
- On collision send jam signal, then back off and retry
- Binary exponential back-off: wait = $k * \text{slot_time}$; $k \in [0, 2^n - 1]$, $n = \text{collision attempts}$
- Operates at Layer 2 (Data Link) — legacy wired

ARP (Address Resolution Protocol)

- Maps IPv4 addresses → MAC addresses on a LAN
- Broadcast ARP request: Who has IP X?; target replies with MAC
- Bridges network (Layer 3) to Data Link (Layer 2)
- Stateless and dynamic (entries cached with TTL)

ARP: Security Weaknesses

- Unauthenticated: any host can send ARP replies
- No validation of responses — trust by default
- Allows spoofing, table poisoning, and traffic redirection
- Greatest risk inside shared L2 broadcast domains

ARP Poisoning (ARP Spoofing)

- Attacker sends forged ARP replies mapping victim IP to attacker MAC
- Victim updates ARP cache and sends traffic to attacker
- Used for Man-in-the-Middle (MitM), sniffing, session hijack, DoS
- Often silent — relies on trust in LAN

Mitigations against ARP Poisoning

- Network access control (802.1X) to block rogue devices
- Dynamic ARP Inspection (DAI) on switches to validate ARP vs DHCP snooping
- Static ARP entries for critical hosts (limited scalability)
- Use encryption (TLS/HTTPS, VPNs) so intercepted traffic is protected
- Monitoring/IDS to detect ARP anomalies

IEEE 802.1X (Port-based Network Access Control)

- Operates at Layer 2 to authenticate devices before granting access
- Components: Supplicant (client), Authenticator (switch/AP), Authentication Server (RADIUS)
- Uses EAP methods to carry credentials; blocks port until success

EAP-TTLS (EAP - Tunneled TLS)

- EAP method that establishes a TLS tunnel to protect credential exchange
- Server presents certificate; client verifies server
- Inside tunnel, client sends legacy auth (PAP/CHAP/MS-CHAP) securely
- Used in enterprise Wi-Fi and wired 802.1X deployments

TLS in EAP-TTLS and Key Exchange

- TLS tunnel established during Phase 1 using a TLS handshake
- Key exchange commonly uses ephemeral Diffie-Hellman (DHE) or ECDHE
- Provides confidentiality, integrity, and optional forward secrecy
- Mutual authentication: server cert + client credentials inside tunnel

Where TLS Sits (Practical View)

- Traditionally between Transport and Application layers (a 'shim' layer)
- In EAP-TTLS TLS is carried inside EAP at Layer 2 — shows TLS can be encapsulated
- TLS 'cuts across' OSI boundaries when tunneled by other protocols

Layered Defense against ARP Poisoning

- Pre-access: IEEE 802.1X + EAP-TTLS to block unauthorized devices
- Network controls: DHCP snooping + Dynamic ARP Inspection on switches
- Endpoint: Use TLS/HTTPS and VPNs to protect application data
- Monitoring: ARP anomaly detection and network segmentation

DNS: Domain Name System

- Translates human-readable names (www.example.com) to IP addresses
- Hierarchical: Root → TLD → Authoritative name servers
- Components: Recursive resolver, root servers, TLD servers, authoritative servers
- Caching improves performance; TTL controls cache lifetime

DNS Security Threats (Summary)

- DNS Spoofing / Cache Poisoning
- DNS Tunneling (covert channels)
- DNS Amplification (DDoS)
- Domain Hijacking / DNS Hijacking
- NXDOMAIN flood attacks

DNS Spoofing / Cache Poisoning

- Attacker injects false DNS responses into resolver cache
- Resolvers return attacker-controlled IPs for legitimate names
- Used for phishing, traffic interception, malware distribution
- Mitigation: DNSSEC, resolver hardening, minimize open resolvers

DNS Tunneling

- Abuses DNS queries/responses to carry arbitrary data (covert channel)
- Used for data exfiltration and C2 channels
- Detection via unusual DNS volumes, long/encoded labels, uncommon record types
- Mitigation: DNS traffic monitoring, block suspicious domains, egress filtering

DNS Amplification Attacks

- Attacker sends small spoofed queries to open resolvers; responses flood victim
- Reflection + amplification; large UDP responses amplify traffic
- Mitigation: Disable open recursive resolvers, rate-limiting, BCP38 ingress filtering

Domain Hijacking & DNS Hijacking

- Domain Hijacking: attacker gains control of domain at registrar
- DNS Hijacking: changing DNS records (router compromise, DNS provider breach)
- Mitigation: Registrar locks, 2FA, monitor DNS records, secure DNS providers

NXDOMAIN Attacks

- Floods resolvers with queries for non-existent domains to exhaust resources
- Mitigation: Query rate-limiting, caching of negative responses, resolver scaling

DNSSEC — What and Why

- DNS Security Extensions: add digital signatures to DNS records
- Provides authenticity and integrity (not confidentiality)
- Uses DNSKEY, RRSIG, DS, and NSEC/NSEC3 records
- Protects against spoofing and cache poisoning by chain of trust

DNSSEC Keys: ZSK and KSK

- ZSK (Zone Signing Key): signs zone RRsets (rotated frequently)
- KSK (Key Signing Key): signs DNSKEY RRset and links to parent via DS
- Chain of trust: Root → TLD → Child; parent stores DS record of child's KSK
- Key rollover: ZSK frequent; KSK less frequent and carefully managed

SSL / TLS — Brief Overview

- TLS secures transport: confidentiality, integrity, authentication
- TLS 1.2 and 1.3 are current standards (use 1.3 where possible)
- TLS handshake: ClientHello, ServerHello, key exchange (often ECDHE), certificates, finished
- Provides transport security for HTTPS, email, VPNs, and more

How TLS Helps Against DNS Attacks

- If DNS redirects you to an attacker, TLS certificate checks expose forgery
- HTTPS/TLS prevents silent content tampering and MitM (certificate mismatch alerts)
- Combine TLS with DNSSEC + DoT/DoH for stronger end-to-end protection

Encrypted DNS: DoT and DoH

- DoT (DNS over TLS): DNS queries over TLS (port 853)
- DoH (DNS over HTTPS): DNS queries over HTTPS (port 443)
- Protects confidentiality and integrity of DNS queries from on-path observers

IPSec — Protecting IP Traffic

- Operates at Network Layer (Layer 3) to secure IP packets
- Core components: AH (auth header), ESP (encapsulating security payload), IKE (key exchange)
- Modes: Transport (payload only) and Tunnel (encapsulate full packet)

IKE (Internet Key Exchange) — Summary

- IKEv2 is current standard: efficient 4-message setup (IKE_SA_INIT + IKE_AUTH)
- Performs Diffie-Hellman key exchange (DHE/ECDHE), negotiates SAs, authenticates peers
- Supports NAT traversal (UDP 4500), mobility, and rekeying

IPSec for VPNs

- Common for site-to-site and remote-access VPNs
- Tunnel mode encapsulates full IP packets between gateways
- Authentication via PSK or certificates; keys managed by IKE

TLS vs IPsec (When to Use Which)

- TLS: Application-layer/transport security (HTTPS, app-specific control)
- IPsec: Network-layer, transparent to apps (site-to-site VPNs)
- Choose TLS for app-specific encryption; IPsec for full-network tunneling

Best Practices — Summary

- Use layered defenses (802.1X, network controls, encryption, monitoring)
- Harden DNS: DNSSEC + DoT/DoH + secure resolvers
- Protect endpoints: TLS/HTTPS, secure cookies, HSTS, CSP for web apps
- Harden infrastructure: patching, least privilege, secure key management

OSI 7-Layer Model (Diagram)

Application → Presentation → Session → Transport → Network → Data Link
→ Physical

Top (user) to bottom (bits on wire). Each layer provides services to the one above.

CSMA/CD Process

1. Station listens to medium (Carrier Sense)
 2. If idle → transmit; if busy → wait
 3. If collision detected → send jam signal
 4. Backoff: wait random $k * \text{slot_time}$, retry
- Binary exponential backoff after multiple collisions.

ARP Request/Reply Flow

Host A needs MAC for IP X:

- Broadcast: Who has IP X?
- Host B replies with its MAC
- Host A updates ARP cache

(Layer 2 ↔ Layer 3 mapping)

ARP Poisoning Attack Flow

Attacker sends forged ARP reply:

Victim's ARP cache updated → IP of gateway now maps to attacker MAC

Traffic is routed via attacker (MitM)

Attacker forwards or drops packets.

802.1X and EAP-TTLS

Authentication Flow

Supplicant (client) ↔ Authenticator (switch/AP) ↔ Authentication Server (RADIUS)

1. EAPOL start
2. EAP exchange (identity)
3. TLS handshake inside EAP-TTLS
4. Tunnel established → client credentials sent securely
5. Access granted if authentication succeeds.

TLS Handshake (simplified)

1. ClientHello → supported ciphers, random nonce
2. ServerHello → chosen cipher, certificate, DH params
3. Key Exchange (ECDHE/DHE)
4. Client verifies cert, sends Finished
5. Server Finished → secure channel established.

DNS Resolution Flow

Client → Recursive Resolver → Root → TLD → Authoritative NS → Response
cached

Each step returns referral until final IP is resolved.

Caching improves efficiency.

DNS Cache Poisoning Attack

Attacker injects forged DNS response:
Resolver caches incorrect IP for domain
Future queries return attacker-controlled IP
Users redirected to malicious site.

DNSSEC Validation Chain

Root signs TLD DS → TLD signs zone DS → zone signs records with ZSK
Resolvers validate signatures via chain of trust.
Ensures authenticity and integrity of DNS data.

IPSec and IKEv2 Flow

1. IKE_SA_INIT: negotiate crypto, exchange DH keys
 2. IKE_AUTH: authenticate peers, set up child SAs
 3. ESP (Encapsulating Security Payload) used to encrypt traffic
- Tunnel mode: full packet encapsulated → secure VPN channel.